NetGuard Pi — FYP-2 Defense Guide

Custom rules vs. Emerging Threats · Demo-day setup · Q&A with live evidence

Sada Ullah · Syed Noroz Ali · Muhammad Aashan Hussain | Supervisor: Dr. Muhammad Mansoor Alam | Riphah International University

1. The big question: “Why custom rules when ET already has 50,000+?”

This was asked in FYP-1. Here is the honest, evidence-backed answer for FYP-2. **Do not claim ET cannot detect these attacks** — our own logs show ET does detect the scan. The real point: a generic ruleset gives raw symptoms; our custom rules add clarity, tuning, prevention, and demonstrate our own skill. Writing custom rules on top of a big feed is **standard professional practice** — Suricata even ships an empty `local.rules` file specifically for this.

The five reasons (each can be shown live)

- **ET gives symptoms, not a verdict.** One scan makes ET fire a separate alert for every port it touches (‘suspicious inbound to MySQL’, ‘to Oracle’, ‘to MSSQL’…) — scattered alerts, none saying ‘this is a scan’. Our rule gives one clear alert: ‘NMAP Scan Detected’.
- **ET misses stealth scans.** For XMAS, NULL and FIN scans ET is largely silent; our flag-based rules (SIDs 1000002–1000004) catch them.
- **We tuned thresholds to our network.** ET’s thresholds are fixed for enterprise traffic; we tuned count/seconds for our lab → zero false positives.
- **Custom rules make prevention possible (NEW in FYP-2).** ET rules only ‘alert’. To actively **drop/block** attacks in IPS mode we wrote our own ‘drop’ rules. Without custom rules there is no prevention layer.
- **It demonstrates we can write and tune IDS rules ourselves** — a core skill of the degree, not just deploying someone else’s rules.

Lead with reason 4 if pushed — it is undeniable

Emerging Threats rules use the `alert` action — they only report. Our IPS mode **drops** attacks, and a `drop` action must be written into a rule. So our custom drop-rules are literally what turns detection into prevention. The 50,000 ET rules cannot do that on their own.

Model answer (quotable)

> *“Sir, the 50,000 Emerging Threats rules are generic and built for the whole internet, not for our specific environment. ET detects the scan too — but as five scattered per-port alerts that never say ‘this is a scan’. Our custom rules give one clear labelled alert, catch stealth scans ET misses, are threshold-tuned to our lab for zero false positives, and — most importantly in FYP-2 — they are what make our IPS prevention possible, because ET rules only alert while our custom drop-rules actively block. They work as a second layer on top of ET, and they prove we can write and tune rules ourselves.”*

Analogy

The ET ruleset is like a standard car alarm that beeps at everything. Our custom rules are like tuning that alarm to our own house — ignore the cat, alert loudly on the actual window being opened. Same engine, tuned to our environment and purpose.

Live before/after evidence (captured on the Pi)

Custom rules OFF	Custom rules ON
One scan → 5 scattered ET per-port alerts (MySQL, PostgreSQL, Oracle, MSSQL, VNC). No clear verdict.	Same scan → our clear labelled alerts (NMAP SYN / Port / Service Scan, FYP-IDS SCAN) **plus** the ET alerts.

Screenshot both and keep them for the report — this proof on screen ends the question.

Anticipated follow-ups

- **"But ET already caught the scan."** → "Yes — as five scattered per-port alerts with no verdict. Ours gives one clear labelled alert, and ours also drives the IPS blocking."
- **"How many custom rules, and where?"** → "18 — 13 in /etc/suricata/rules/local.rules (SIDs 1000001–1000013) and 5 team rules (9000001–9000005), loaded with the ET rules: 50,193 total, 0 failed."
- **"Show me one."** → open local.rules, point to a SYN-scan rule, explain the threshold: count 5, seconds 3 tuning.

---

2. Your two rule sources & the verified numbers

Every alert comes from one of two places. Tell them apart by the SID range:

- **Your custom rules** — SIDs **1000001–1000013** and **9000001–9000005** (18 total).
- **Emerging Threats rules** — SIDs in the **2xxxxxx** range (e.g. 2008453). You did **not** write these.

What	Value (verified on the Pi)
Total rules loaded	**50,193**, 0 failed
Custom rules	18 = 13 + 5
13 detection rules	/etc/suricata/rules/local.rules (SIDs 1000001–1000013)
5 team rules	/var/lib/suricata/rules/local.rules (SIDs 9000001–9000005)

Prove it live (one command — also proves 0 failures, NFR-05):

```
sudo grep "rules successfully loaded" /var/log/suricata/suricata.log
```

Count / list your own rules:

```
sudo grep -rhoE "sid:(1000[0-9]{3}|9000[0-9]{3})" /etc/suricata/rules/local.rules
 /var/lib/suricata/rules/local.rules | sort -u
```

Note: having two files named local.rules is just organisation — both are loaded via the `rule-files` list in suricata.yaml. There is no technical difference between them.

---

3. The "Tomcat Brute Force" alert (2008453) — a false positive, explained

This HIGH alert is an **ET rule** (SID 2008453, 2xxxxxx range) — not ours. It fired on our own dashboard traffic. Here is why, so you can explain it confidently:

- The rule matches the HTTP header `Authorization: Basic YWRtaW46` — and **YWRtaW46 is Base64 for 'admin:'**. So it looks for HTTP Basic-Auth logins using username 'admin'.
- Its threshold is `count 5, seconds 30, track by_src` — it fires after 5 such logins from one source in 30 seconds.
- Our dashboard uses admin Basic-Auth on port 8080 (the default Tomcat port). The browser re-sends the auth header on every request, so a few refreshes = 5+ 'admin' logins in 30s = the rule fires. A textbook false positive on our own login.

Own it as a strength:

> *"This HIGH alert is ET rule 2008453, not one of ours. It detects 5+ admin Basic-Auth attempts in 30 seconds and fired on our own dashboard traffic — a false positive we manage by accessing the dashboard locally. It also proves the Emerging Threats ruleset is live alongside our 18 custom rules."*

Related honest note (ET rule 2006380): ET also flags that the dashboard sends the admin password in cleartext Basic-Auth over HTTP. Own it: "a known limitation — future work is serving the dashboard over HTTPS/TLS." Self-awareness scores marks.

---

4. Demo-day networking — no router needed

The attack demo runs entirely between Kali and the Pi on your own wired lab network. **The university network plays no part — do not run attacks on it** (policy risk + unpredictable DHCP). Recreate your lab with one RJ45 cable and static IPs.

Device	Static IP	Role
Pi eth0	192.168.10.50	IDS/IPS sensor
Kali (VirtualBox)	192.168.10.20	attacker
Laptop Ethernet	192.168.10.1	view dashboard / VNC

- **VirtualBox:** Kali → Settings → Network → Adapter 1 = **Bridged Adapter**, bound to your laptop's **Ethernet** adapter (NOT Wi-Fi, NOT NAT). If NAT, Kali cannot reach the Pi.
- **Show the dashboard the reliable way:** VNC to the Pi at 192.168.10.50, then open `http://localhost:8080` inside the Pi's desktop. localhost never changes — no DHCP/Wi-Fi surprises, and the dashboard false positives disappear (that traffic never crosses eth0).
- **Email alerts need internet:** connect the Pi's Wi-Fi (wlan0) to your phone hotspot just for internet; the cable (eth0) runs the lab. Or show a pre-captured email screenshot.

Set the Pi's eth0 static:

```
sudo nmcli con show

sudo nmcli con mod "Wired connection 1" ipv4.addresses 192.168.10.50/24 ipv4.meth
od manual

sudo nmcli con up "Wired connection 1"
```

Pre-flight ping test (must pass both ways before you present):

```
# from Kali:   ping 192.168.10.50 # from the Pi: ping 192.168.10.20
```

5. Demo-day checklist

- ■ Connect Pi ↔ laptop with the RJ45 cable (bring your own cable!)
- ■ Static IPs set: Pi eth0 = .50, Kali = .20, laptop = .1 — verify with hostname -I
- ■ VirtualBox Kali network = Bridged to the Ethernet adapter
- ■ Ping works both ways (Kali ↔ Pi)
- ■ Rules enabled — suricata -T shows 50,193 loaded, 0 failed
- ■ Suricata running — sudo systemctl status suricata
- ■ Start clean: flush old blocks — sudo iptables -F FYP-BLOCK 2>/dev/null
- ■ Dashboard opens via VNC → localhost:8080
- ■ One full attack tested end-to-end (nmap -sS → alert on dashboard)
- ■ Decide start mode: IDS for detection, then switch to IPS live
- ■ Phone hotspot ready for email (or screenshot backup)
- ■ Backup SD card / screenshots of before-after evidence

6. Quick command reference

```
# rules loaded (proves 50,193 / 0 failed)
sudo grep "rules successfully loaded" /var/log/suricata/suricata.log

# watch alerts live sudo tail -f /var/log/suricata/fast.log

# run attacks from Kali sudo nmap -sS 192.168.10.50      # SYN scan
sudo nmap -sX 192.168.10.50      # XMAS stealth scan (custom rules shine here)

# config test (counts rules without touching live traffic)
sudo suricata -T -c /etc/suricata/suricata.yaml -v 2>&1 | grep loaded
```

Reminder: SIDs 1000xxx / 9000xxx = yours; 2xxxxxx = Emerging Threats.